

Incident Response

Security incidents like DDoS attacks email malware executable or whatever are all security incidents

NIST SP800-61 is how companies handle the security incidents

Prepping for an incident:

Communication methods:

- Phones and contact info

Incident handling hardware and software:

- Laptops removable media forensic software etc

Incident analysis resources:

- Documentation, network diagrams, baselines, critical file has values

Incident mitigation software:

- Clean OS and app images

Policies needed for incident handling:

- Everyone knows what to do

The challenge of detection

- Many different detection sources and large amounts of volume

Attacks are coming in all the time

Which ones are the ones that are threatening

Incidents are almost always complex

Look at your system log fool

Monitoring and Analysis can help you detect an attack so you can react fast to deal with the attacker

Stop attacker as soon as possible and test best defenses in a sandbox. Then recover after the incident. Use a good back up after the malware or bug is removed

Lesson learned and post incident meeting

Dont wait to long and have better plan for next attack

What happened , how did incident plan work, what are some changes this is common sense

Digital forensics

RFC 3227 - Guidelines for Evidence Collection and Archiving

TAKE EXTENSIVE NOTES LOTS OF NOTES

Legal Hold:

A legal technique to preserve relevant info:

- Prepare for impending litigation
- Initiated by legal counsel

Hold notification:

- custodians are instructed to preserve data

Separate repository for electronically stored information (ESI):

- Many different data sources and types
- Unique workflow and rendition requirements

On going preservation:

- Once notified, there's an ongoing obligation to preserve data

Chain of custody:

Control evidence:

- Maintain Integrity

Everyone who contacts the evidence:

- Use hashes and digital signatures
- Avoid tampering

Acquisition of data;

Obtain the data:

- Disk, RAM, firmware, OS files, etc

Some of the data may not be on the same machine

Look behind digital items:

- Artifacts log info etc

Reporting:

Document the findings

- For internal use, legal proceedings, etc

Summary information:

- Overview of the security event

Detailed explanation of data acquisition:

- Step by step method of the process

The findings:

- An analysis of the data

Conclusion:

- Profession results, given the analysis

Preservation is key where to store

Isolate and protect data

MAKE COPIES

Live collection has become an important skill:

- Data may be encrypted or difficult after powering down

Follow best practices for everything

E discovery:

Collect, prepare, review, interpret and produce electronic docs

4.9 Log Data

Firewall logs

Traffic flows through the firewall:

- Source / Dest IP, Port number, disposition

NGFW:

- Logs the app used, URL filtering and categories, anomalies and suspicious data

App logs:

Specific to the app:

- info varies widely

Windows:

- Event viewer / app log

Linux/Macos:

- Var/log

Parse the log details on the SIEM:

- Filter unneeded data

Endpoint logs:

Endpoints are phones, laptops, tablets, etc

There's a lot of data on the endpoint obviously

Everything rolls up to SIEM:

- Security Information and Event Manager

Use with correlation of security events:

- Combine IPS events with endpoint status

OS specific security Logs:

Logs related to OS security events

Find problems before they happen;

- Brute force attacks and disabled services

May require filtering

IPS/IDS logs:

- Usually integrated with NGFW

Logs contain information. About predefined vulnerabilities

Network logs:

- Switches routers access points VPN concentrators

Network changes;

- Routing updates
- Authentication issues
- Network issues

Metadata:

- Data that describes other data sources

Email:

- header details, sending servers, destination address

Mobile:

- Type of phone, Gps location

Etc etc

Vulnerability scans:

Lack of security controls obviously

Misconfigs:

- Open shares
- Guest access

Real vulnerabilities:

- Especially newer ones
- Occasionally the old ones

Automated reports:

Most SIEMs include a report generator:

- Automate common security reports

May be easy or complex to create:

- The SIEM may have its own report generator

Requires human intervention:

- Someone has to read the reports

These can be involved to create:

- Huge data storage and extensive processing time

Dashboards:

- Realtime status info
- Add or remove info

Shows the important data

Packet captures:

Solve complex app issues:
-get into the weeds

Gather packets on the network:
- Or in the air
- Sometimes built into the device

View detailed traffic information:
- Identify unknown traffic
- Verify packet filtering and security controls
- View a plain language description of the app data

Wireshark